

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 4:	Pentest em Aplicações Web
Atividades:	Information Disclosure
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Pentest em Aplicações Web*, para a qual utilizamos a sala do PortSwigger - <https://portswigger.net/>

No contexto desta sala, nosso foco é:

- 1) Conseguir informações através de mensagens de erro, para encontrar programas vulneráveis que possam ser explorados;
- 2) Utilizar o indexador robots.txt para conseguir possíveis caminhos de diretórios expostos na internet, senhas de banco de dados, qual banco de dados é utilizado;
- 3) Acessar o repositório git através da internet site.com/.git, conseguir as credenciais usuário e senha para conseguir acesso de administrador no site.

A sala do Portswigger é composta por três tarefas:

- 1) Divulgação de informações em mensagens de erro: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-error-messages>
- 2) Divulgação do código-fonte por meio de arquivos de backup: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-via-backup-files>
- 3) Divulgação de informações no histórico de controle de versão: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-version-control-history>

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

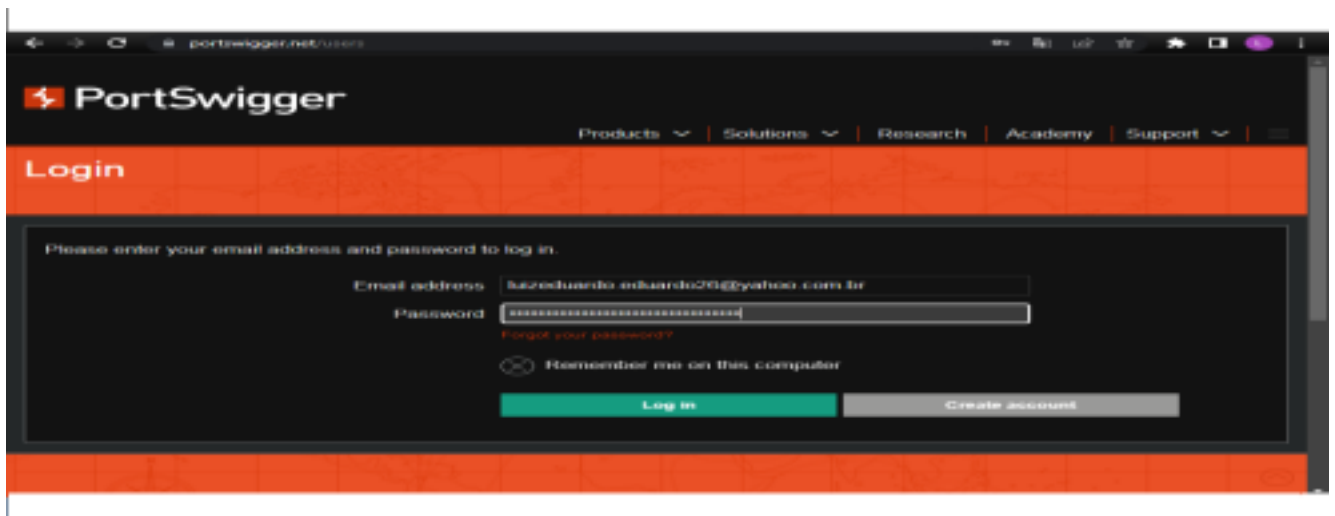
- 1) Acessar os sites informados acima.
- 2) Utilizar a VM do Kali Linux: Para utilizar o Burp e executar alguns comandos no terminal.

2.2. Atividade prática

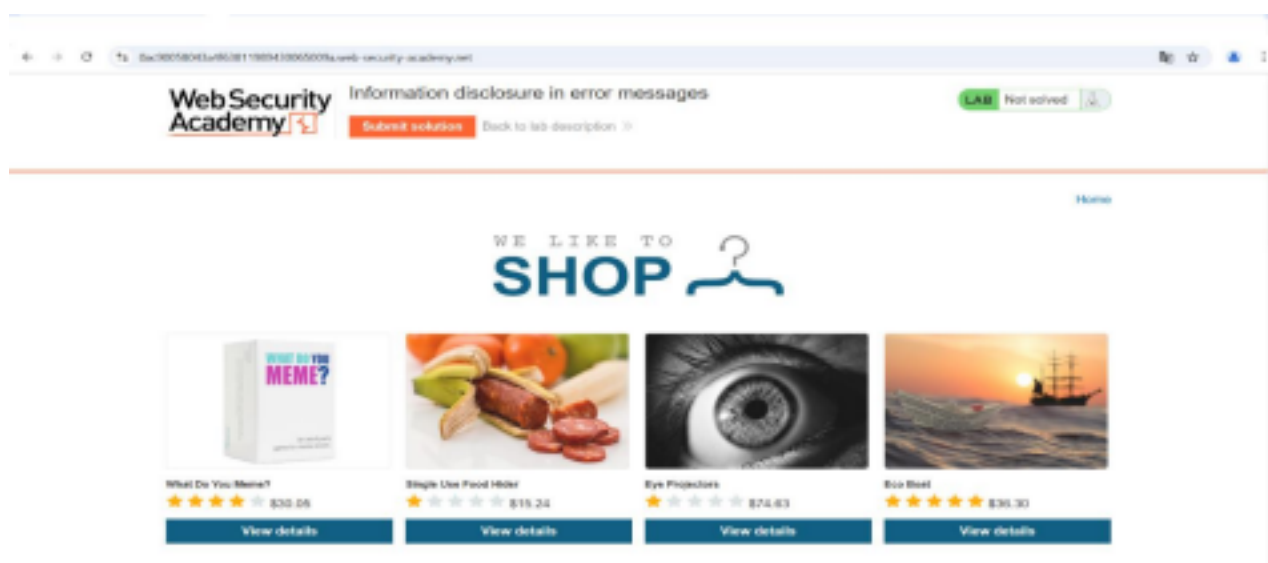
O objetivo desta atividade é realizar as 3 tarefas propostas no PortSwigger

2.3. Atividade 1 - Divulgação de informações em mensagens de erro

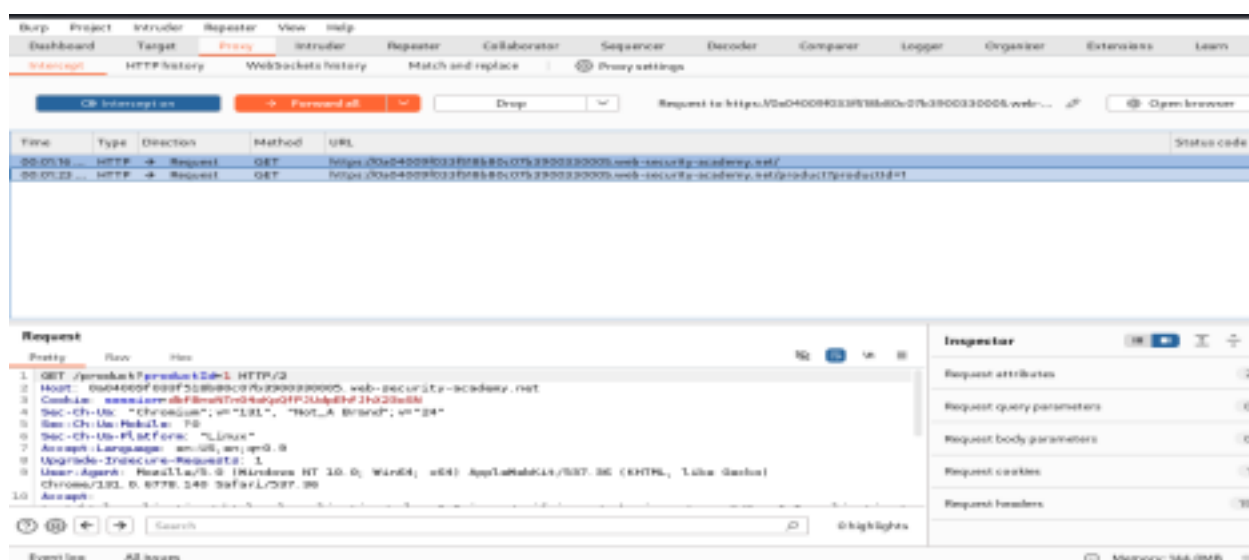
Passo 1 – Entre com seu login e senha no PortSwigger no site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-error-messages> e clique em acesse o laboratório



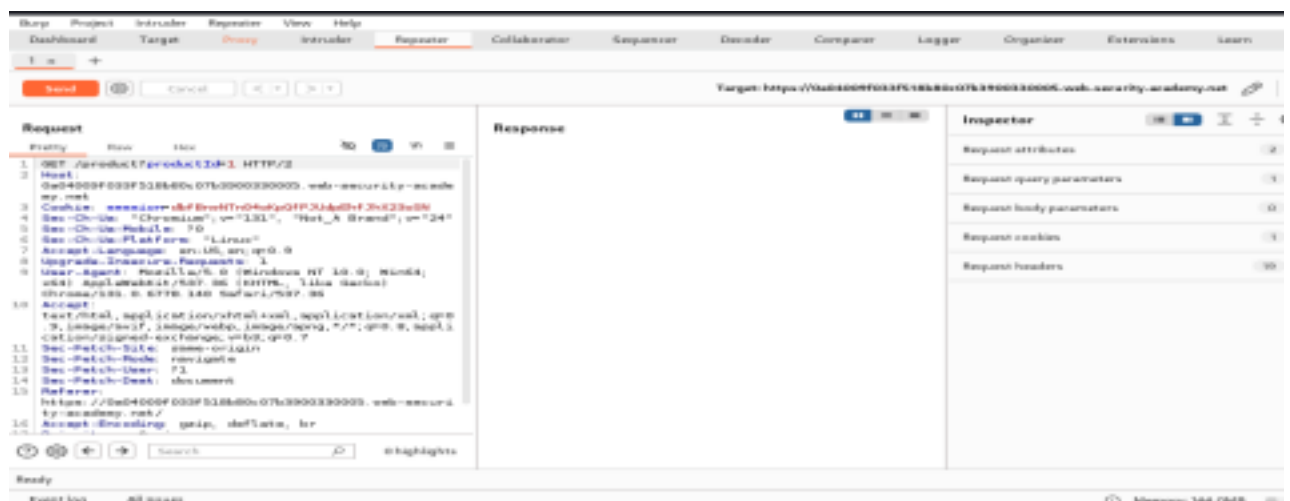
Passo 2 – Vai aparecer o site: <https://0ac90058043a4f63811989430065009a.web-security-academy.net/>



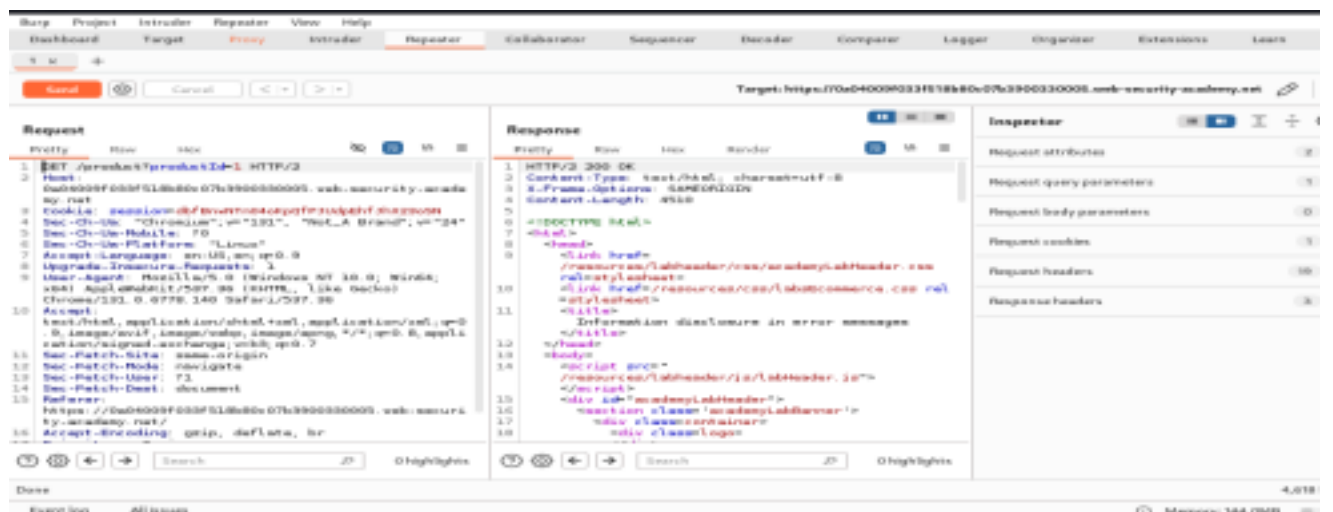
Passo 3 – Abra o Burp Community vá até Proxy clique em Intercept e depois em Intercept On caso esteja em off, depois acesse um produto e sempre clique em forward para que a página seja carregada em seu navegador



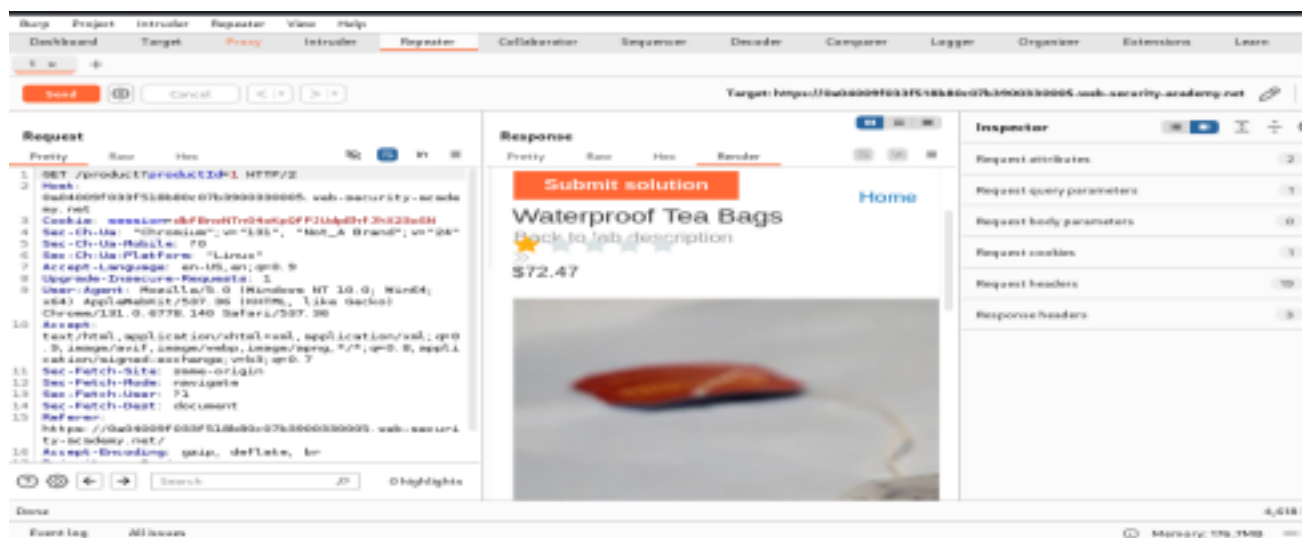
Passo 4 – Clique com o botão direito do mouse no site do produto que escolheu e clique em Send to Repeater



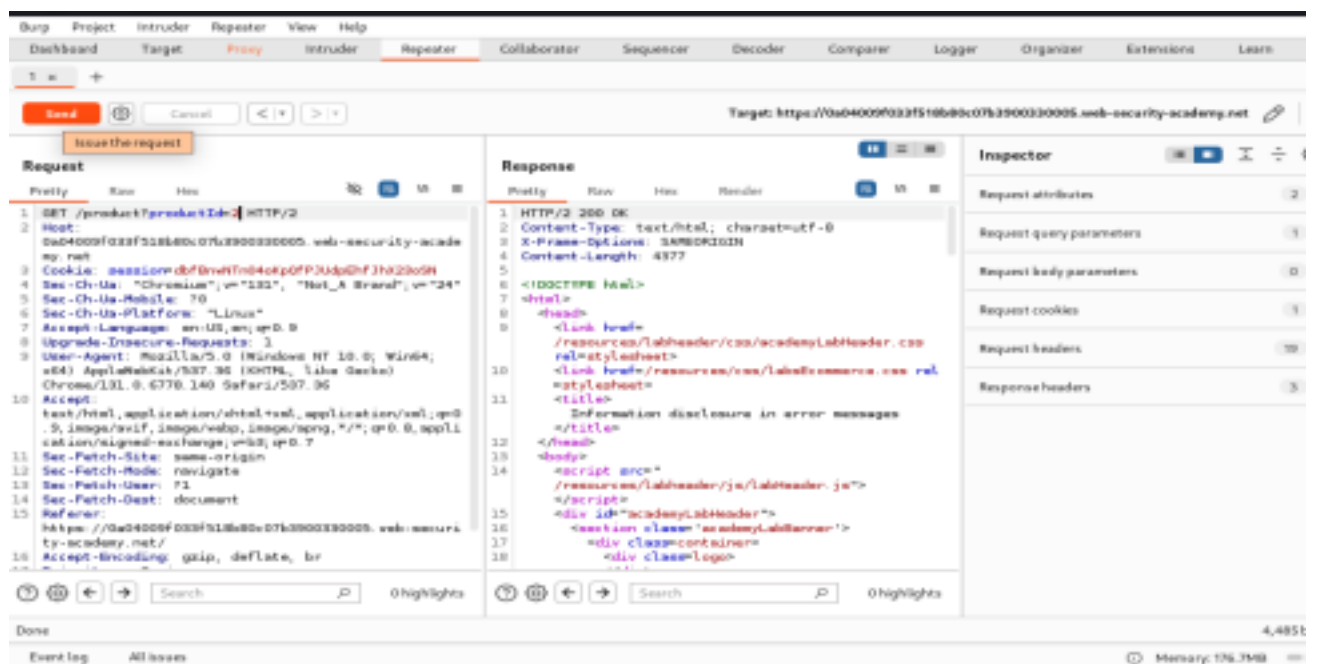
Passo 5 – Agora clique em Send que irá aparecer o código HTML em Pretty



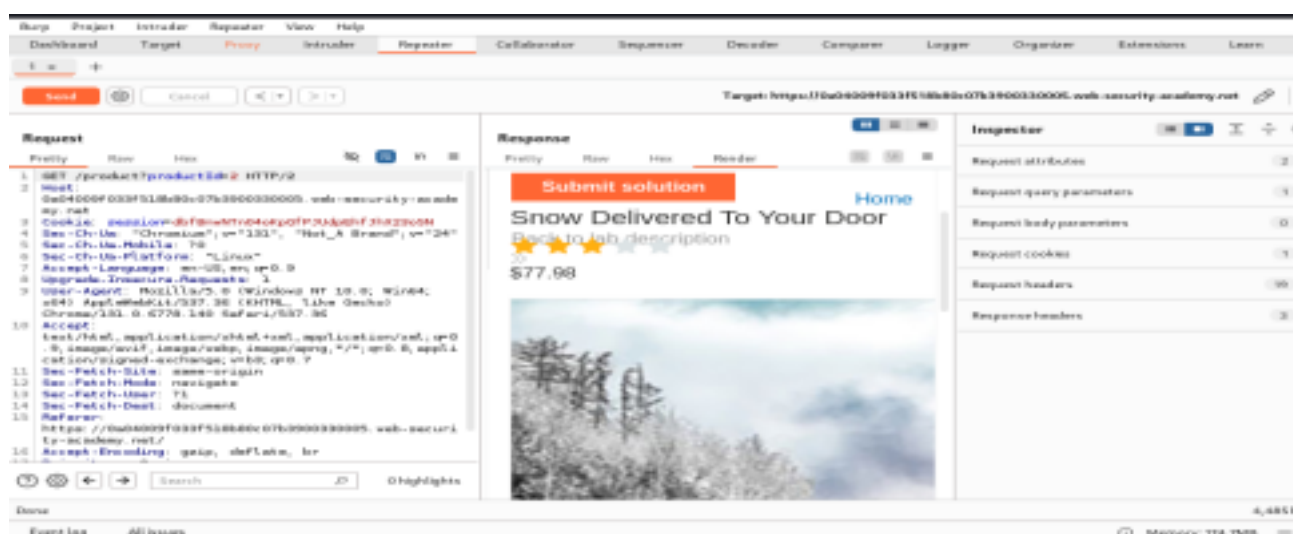
Passo 6 – Agora clique em Render que aparecerá a mesma página que consta no seu navegador.



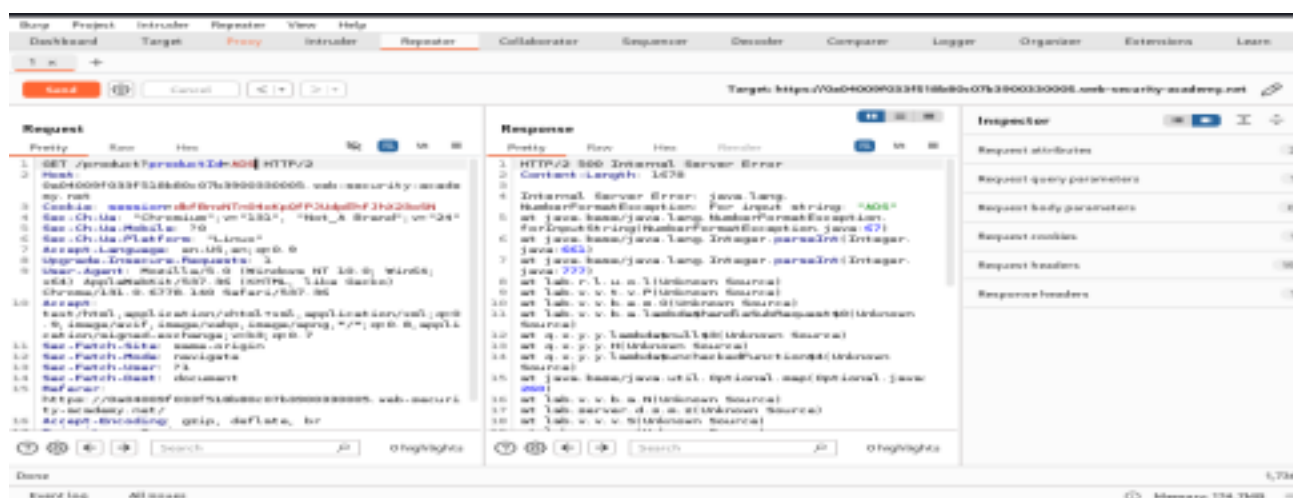
Passo 7 – Agora mudei o productId para 2 e clique em Send aparecerá outro código no pretty pode verificar que o content-length é menor que o primeiro.



Passo 8 – Agora clique em Render e verá que a imagem é diferente do productId=1



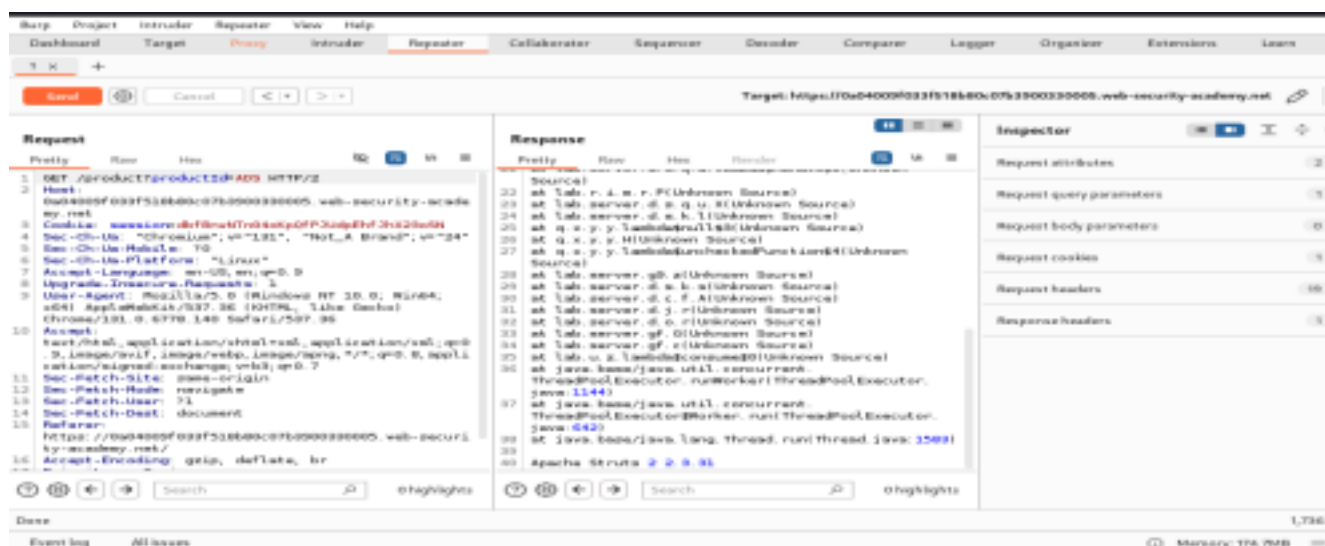
Passo 9 – Agora colocaremos um texto no productId = ADS para verificar o que acontece, ele mostrou um erro no pretty vemos que foi um erro em Java informando que aceita apenas a classe integer e digitei uma string para causar este erro, pode ser utilizado qualquer outra classe como boolean ou um número grande que não seja integer para causar este erro.



Passo 10 – Pode verificar que quando o erro acontece o botão Render fica desabilitado.



Passo 11 – Verificando o response no pretty indo até o fim do erro aparece que utiliza a versão do Apache Struts 2 2.3.31



Passo 12 – Vou até o site <https://0ac90058043a4f63811989430065009a.web-security-academy.net/> e clico em Submit Solution e digito Apache Struts 2 2.3.31 e OK



7

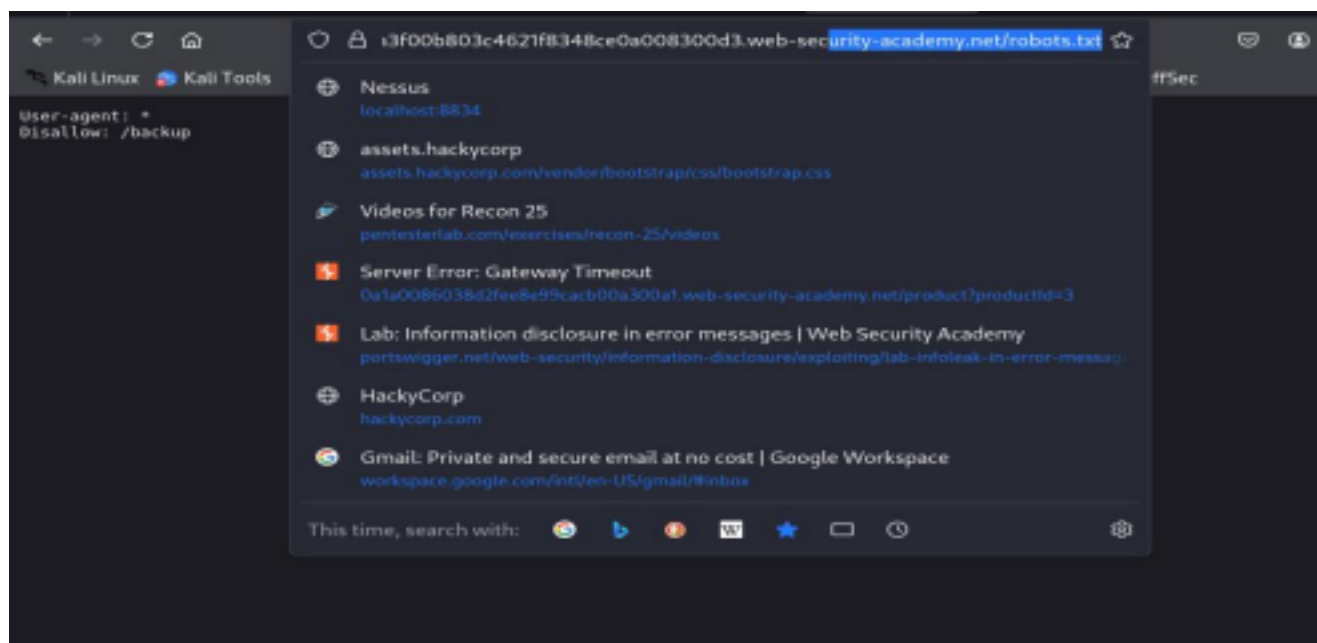
Passo 13 – O site informa que o laboratório foi resolvido com sucesso.



2.4. Atividade 2 – Divulgação do código-fonte por meio de arquivos de backup

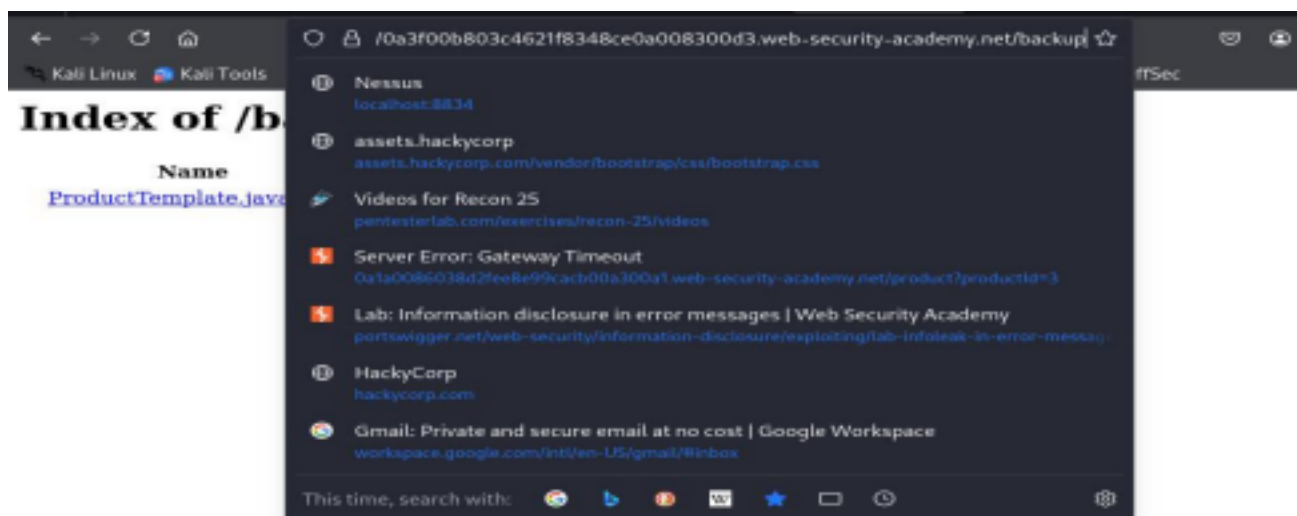
Passo 1 – Abra o browser e digite

<https://0a0e000c04f7c7ef81e2e820000c006f.web-security-academy.net/robots.txt>
precisamos digitar este comando para saber quais páginas este endereço não quer indexadas na pesquisa do Google

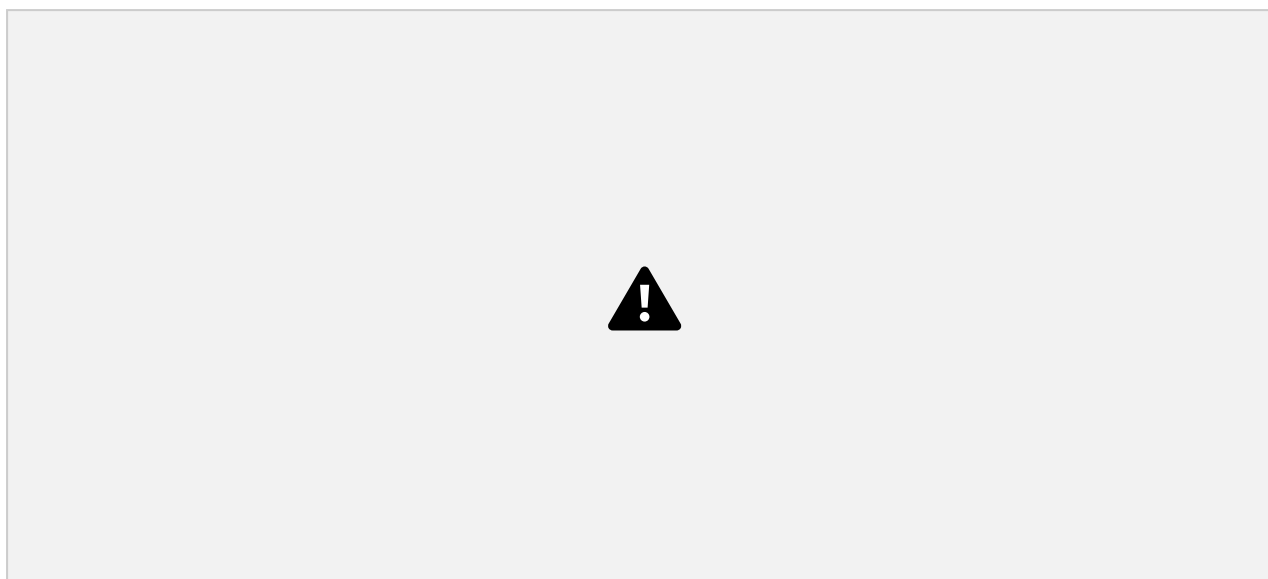


Passo 2 Agora acesse o site da aplicação com o /backup

<https://0a0e000c04f7c7ef81e2e820000c006f.web-security-academy.net/backup>



Passo 3 – Clique no Link ProductTemplate.java.bak, aparecerá a tela abaixo e vemos que ele se conecta a um banco de dados



Passo 4 – Agora ache a senha que está neste arquivo, vimos que utiliza o DB Postgress e encontramos a senha



Passo 5 – Copie a senha abaixo de postgres e coloque na resolução do laboratório



Passo 6 – O site informa que o laboratório foi resolvido com sucesso.



2.5. Atividade 3 – Divulgação de informações no histórico de controle de versão

Passo 1 - Entre com seu login e senha no PortSwigger no site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-version-control-history> e clique em acesse o laboratório



Passo 2 - Vai aparecer o site: <https://0a6a00f5030d2f75916b0e63002c005b.web-security-academy.net/>



Passo 3 - Abra o Burp Community vá até Proxy clique em Intercept e depois em Intercept On caso esteja em off

Figura

Passo 4 – Acessar o site <https://0a6a00f5030d2f75916b0e63002c005b.web-security-academy.net/.git>



Passo 5 – Abrir o terminal e digitar `wget -r` <https://0a6a00f5030d2f75916b0e63002c005b.web-security-academy.net/.git> para baixar para o seu terminal no Kali Linux.



Passo 6 – Depois que baixar o arquivo digite o comando `ls -l` e depois `cd` o nome do arquivo `0a6a00f5030d2f75916b0e63002c005b.web-security-academy.net/.git` e `ls` verificará não terá arquivos



Passo 7 – Depois entre com o comando `cd .git` e depois `ls -l`



Passo 8 - abrir o git cola, clicar em open, ache o arquivo `0a6a00f5030d2f75916b0e63002c005b.web-security-academy.net/.git` e clique nele e aperte em choose



Passo 9 – Clicar em Commit e depois em undo last commit e depois novamente em undo last commit



Passo 10 – Clicar em admin.conf e copie o password do admin



Passo 11 – Volte no site: <https://0a6a00f5030d2f75916b0e63002c005b.web-security-academy.net> clique em my account coloque no username administrator e na senha coloque o password do admin que copiou no git cola. E clique em log in .



Passo 12 – Clique em Admin Panel e delete o usuário Carlos



Passo 13 – Concluiu o laboratório



15

2.8. Análise dos Resultados:

Foi realizada a instalação do Burp Community no Kali Linux

Interpretação dos resultados:

1) No laboratório 1 podemos utilizar a informação que o cliente utiliza o Apache Struts 2 2.3.31 e procurar vulnerabilidades no google que possam ser utilizadas neste alvo; 2) No laboratório 2 podemos utilizar o arquivo de backup para conseguir acesso ao banco de dados, saber qual banco de dados utiliza, qual a senha do banco de dados, chaves API's utilizadas entre outras informações que podem constar no backup. 3) No laboratório 3 podemos recuperar o arquivo .git conseguir o acesso de administrador dentro do site e excluir, renomear, incluir usuários, todas as funções de administrador, neste exercício em específico apenas excluir o carlos;

2.9. Mitigação:

- 1) No laboratório 1 deixar mensagens de erro genéricas para que o site não informe os aplicativos ou sistemas que estão utilizando;
- 2) No laboratório 2 cuidado o que deixa exposto no arquivo robots.txt estes arquivos não devem ser acessados via browser na internet exemplo site.com/backup; 3) No laboratório 3 não deixar o arquivo .git disponível via browser da internet exemplo seusite.com/.git porque pode se recuperar login e senha do administrador. 4) Retirar informações sensíveis da internet
- 5) Retirar documentação exposta para a internet
- 6) Paths de documentação de APIs e aplicações de uso interno devem estar em acesso interno e controlado;
- 7) Treinar a equipe de dev no processo de desenvolvimento seguro e revisão de todas as aplicações antes de sua publicação;
- 8) Realizar a busca de vulnerabilidades nas aplicações com frequência.

3. Considerações finais

Nesta sala, exploramos técnicas Pentest em Aplicações Web com o software Burp Suite Community para manipular algumas requisições e forçar alguns erros, também utilizamos o

browser para conseguir ter acesso ao backup no próprio browser e conseguir a senha e o banco de dados utilizados, outro software utilizado foi git cola para conseguirmos o usuário e senha da conta administrador do site.

As principais lições aprendidas incluem:

- 1) Cuidado ao deixar as informações públicas e acessíveis pelo browser, elas podem ser interceptadas e utilizadas para acesso não autorizado.
- 2) O arquivo robots.txt tem que ser bem direcionado para que os arquivos que constem neles não sejam acessíveis diretamente pelo browser, pois podem ser utilizadas para conseguir senhas, tipo de banco de dados e outras informações que podem ser utilizadas em um ataque.
- 3) O diretório .git também não deve ser acessado diretamente pelo browser, pode se extrair login e senha do administrador dando um acesso quase ilimitado ao atacante.

Foi verificado que é bem fácil alterar os parâmetros no browser, o Burp também é bem fácil de utilizar e tem recursos que deixam a manipulação do site ainda mais fácil como o Repeater.

4. Referências

Site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-error-messages>

Site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-via-backup-files>

Site: <https://portswigger.net/web-security/information-disclosure/exploiting/lab-infoleak-in-version-control-history>